Gianluca Hotz

PASS SQLSATURDAY

SQL Server & GDPR

Sponsor

ENGAGE
IT SERVICES

Microsoft

Bi FACTORY

Elfo

DATA SKILLS
UNDERSTANDING THE WORLD

redgate

MICROSYS

ApexSQL

Digibahn

OverNet
EDUCATION

SentryOne

Organizzatori

GetLatestVersion.it

ENGAGE IT SERVICES

GUISS

PASS

UNIVERSITÀ DEGLI STUDI DI PARMA

daniela malvisi COMMUNICATION

dotNET{podcast}

Gianluca Hotz | @glhotz

Fondatore e Mentor SolidQ

- 20 anni con SQL Server (dalla 4.21 nel 1996)
- Modellazione basi di dati, dimensionamento e amministrazione, sviluppo, ottimizzazione

Interessi

- Modello relazionale, architettura DBMS, alta disponibilità e Disaster Recovery

Microsoft MVP SQL Server dal 1998

Fondatore e presidente UGISS

- User Group Italiano SQL Server (PASS Chapter)

Introduzione

GDPR: General Data Protection Regulation

Normativa Europea (no direttiva!)

Chiunque tratti dati di residenti EU

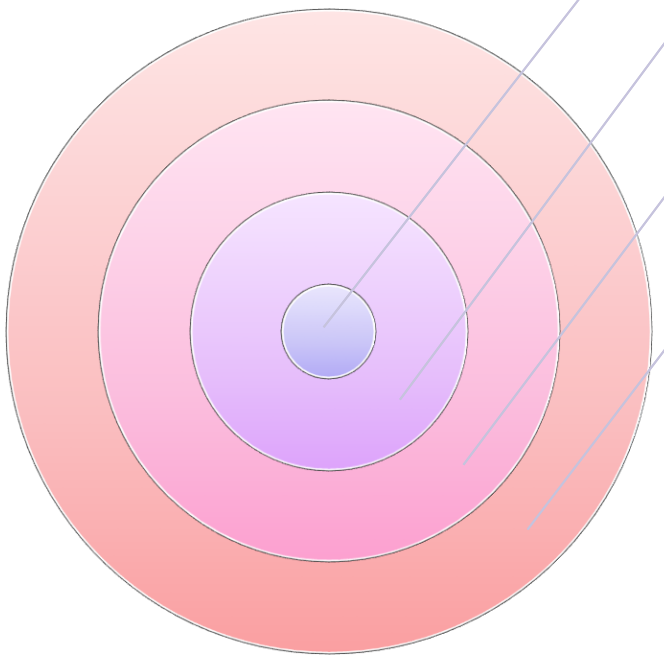
Sanzioni 4% del fatturato o 20mio

25 Maggio 2018 (dopodomani!)

Codici di condotta per Micro/PMI

Approccio strutturato

Security Layering



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Dynamic Data Masking**
- **Row-Level Security**

Access Control

- **Encrypted Authentication**
- **SQL Firewall***

Proactive monitoring

- **Auditing**
- **Threat Detection***

Scoperta e Controllo Accessi

Assessment

Trovare a classificare informazioni in ambito

- Catalogo metadati (es. sys.columns, moduli SQL)
- Ricerche Full-Text in campi liberi

Valutare necessità e proporzionalità protezioni

- nome, e-mail, carta di credito, malattie, affiliazione politica ecc.

Mappare flussi da/verso esterno

Stato dell'arte rispetto a

- Best Practice
- Codice condotta

Controllo degli accessi

Azure Database Firewall (che device)

Autenticazione (chi sono)

Autorizzazioni (cosa posso fare)

Principio guida: minor privilegio!

Azure Database Firewall

Accesso per servizi Azure

Indirizzi IP Specifici

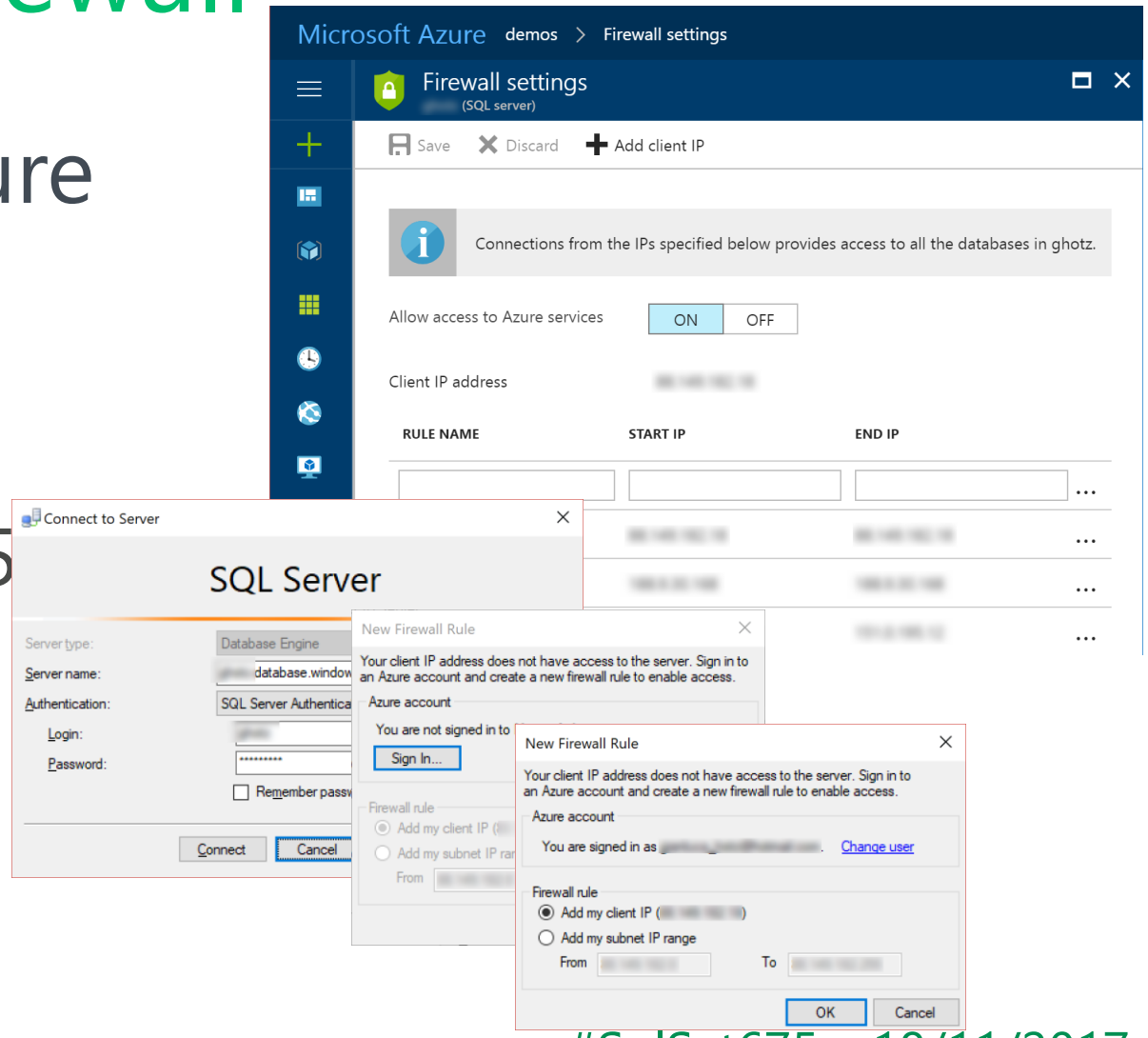
Range di indirizzi IP

No 0.0.0.0-255.255.255

Interfaccia SSMS

Comandi T-SQL

PowerShell, REST API



Autenticazione

Due livelli: Server login e Database User

Nativa SQL Server

Integrata con Active Directory
- Utilizza protocollo Kerberos
- Supporto Azure Active Directory
- Supporto Active Directory Universal Authentication
  - Multi-factor Authentication (es. via telefono)
  - Supportata solo con SSMS a partire dalla versione 17

Best Practice
- Autenticazione integrata
- Database Containment (autenticazione a livello database)

Autorizzazioni

Permessi granulari

- **GRANT** cosa può fare **ON** su che oggetto **TO** chi
- Ereditarietà gerarchia di oggetti
- Assegnazione (GRANT), negazione (DENY), revocare (REVOKE)
- Row Level Security

Ruoli a livello di server e database

- Es. sysadmin, dbcreator, db_datareader, db_datawriter
- Specifici per alcune funzionalità (database msdb)

Principio guida: minor privilegio!

- Possibile elevare temporaneamente
  - Impersonation
  - Stored Procedure (in generale moduli T-SQL firmati)

Protezione

Attore principale: crittografia, ma dove?

- Dati in transito
  - Autenticazione (sempre crittografata)
  - Spostamento dati
    - invio richieste (parametri)
    - caricamento in memoria
    - invio risposte (record set)

- Dati a riposo
  - File database (dati e log transazioni)
  - File di trace/audit

Crittografia comunicazioni

On-premise

- Installazione Certificato (server e client)
- Possibile forzare utilizzo (server e client)
- Autenticazione sempre crittografata (nel caso «self-signed»)

Azure SQL Database (e SQL Data Warehouse)

- Connessione crittografata sempre necessaria!
- Es. connessione ADO.NET *Encrypt=True;TrustServerCertificate=False*

Transport Layer Security (TLS) 1.2

- Windows Server 2008 R2
- SQL Server 2008 SP4 (hotfix)

Crittografia dati prima di SQL Server 2016

Transparent Data Encryption (TDE)

- File dati, log e backup
- Dati decifrati quando caricati in memoria*
- Completamente trasparente per le applicazioni

Cell-Level Encryption (CLE)

- Granularità a livello di Colonna
- Protezione parziale in memoria
- Non trasparente per le applicazioni

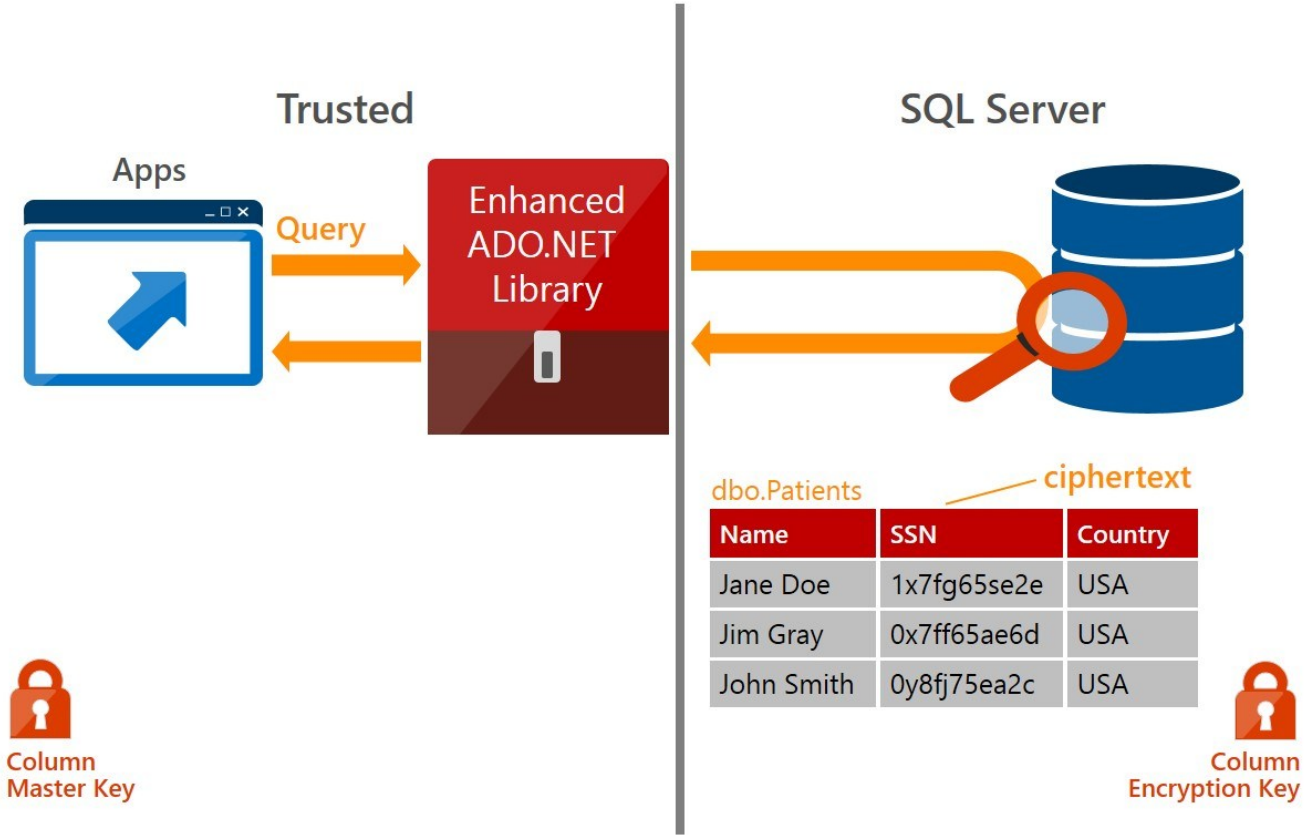
Entrambi meccanismi crittografici Server-Side

- Protezione dati a riposo (es. furto dischi o backup)
- Utenti con privilegi elevati possono ottenere accesso ai dati

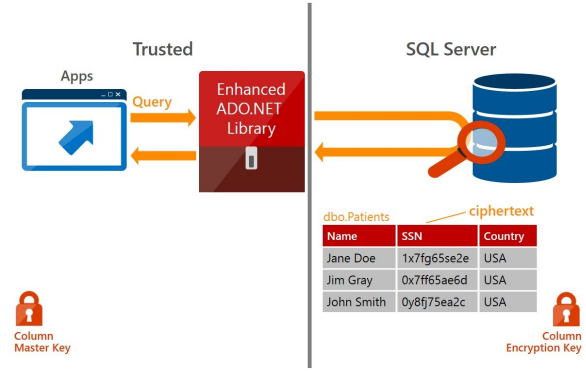
Protezione

Always Encrypted

Panoramica Always Encrypted



Always Encrypted Keys



Column Encryption Key (CEK)

- Usate per crittografare i dati
- Conservate solo in forma crittografata sul server
- Legate a specifiche colonne

Column Master Key (CMK)

- Usate per crittografare le CEK
- Conservate in un «key store» esterno
  - Windows Certificate Store, Azure Key Vault, HSM, Custom
- Deve essere disponibile alle applicazioni

Crittografia dei dati

Deterministica

- Permette operazioni di uguaglianza/raggruppamento/join
- Permette indicizzazione
- Più debole es. domini con pochi valori come sesso o «flag»
- Richiede collation **_BIN2**

Casuale

- Nessuna operazione permessa
- Indicizzazione non permessa
- Più robusta

Configurazione Client Always Encrypted

Stringa di connessione

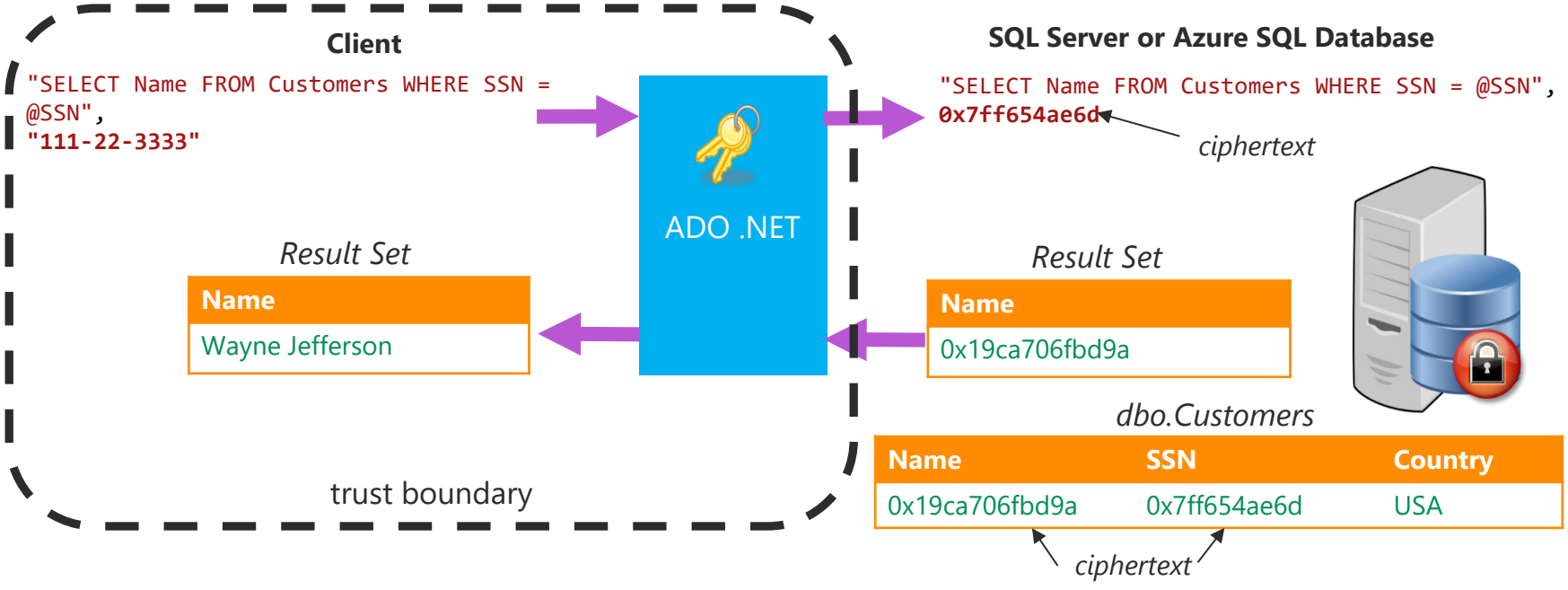
- Column Encryption Setting=Enabled

Esecuzione di comandi

- SqlCommand.ColumnEncryptionSetting*
  - Disabled, Enabled, ResultSetOnly, UseConnectionSetting

Flusso corrispondenze esatte AE

I dati sensibili crittografati con le relative chiavi crittografiche non sono mai disponibili in chiaro sul server!



DEMO

Protezione

Row-Level Security

Panoramica Row Level Security

Restringe l'accesso a un sottoinsieme di righe

Basata su predicati di sicurezza

- Definiti come «inline Table-Valued Functions»
- «Filter predicate» limita righe a operazioni in lettura
  - SELECT, UPDATE e DELETE
- «Block predicate» bloccano operazioni di scrittura
  - AFTER INSERT, AFTER/BEFORE UPDATE, BEFORE DELETE

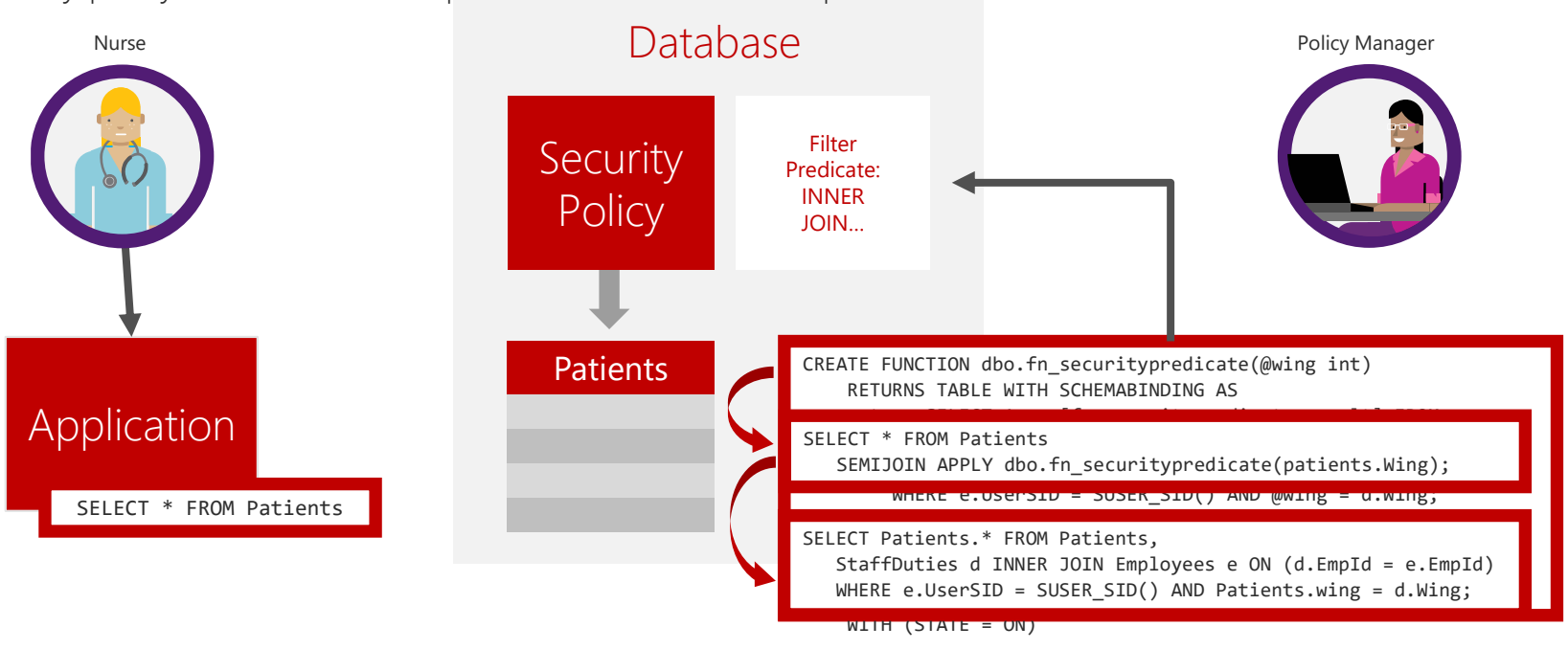
«Security Policy»

- Applica i predicati di sicurezza alle tabelle

Row-Level Security

Due

Con Security Policy si crea un predicato in T-SQL per filtrare i dati in base all'utente che ne fa richiesta e crea «security policy» che vincola tale predicato alla tabella dei pazienti.



DEMO

Protezione

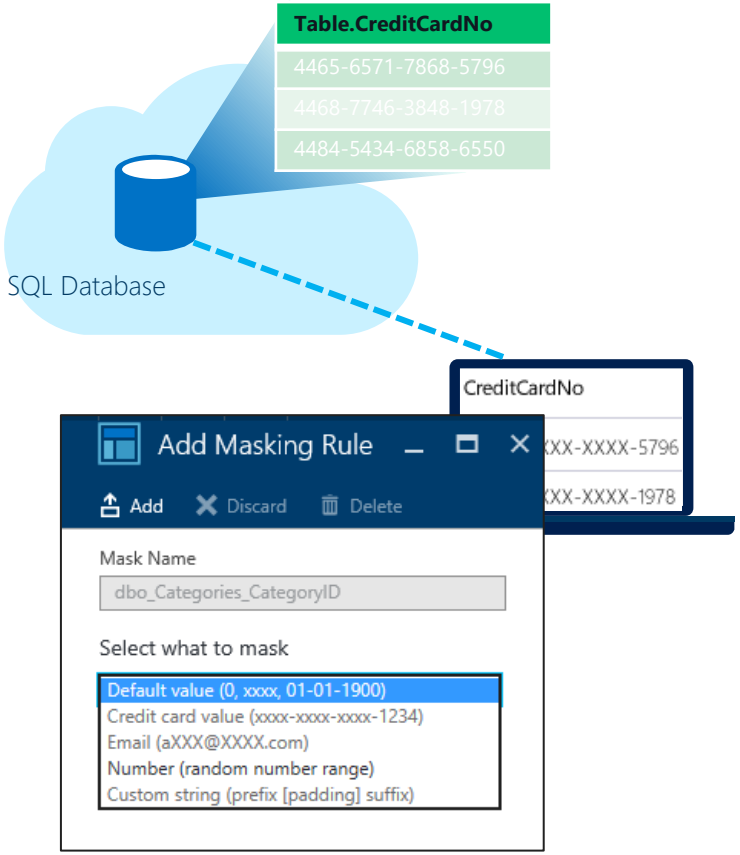
Dynamic Data Masking

Dynamic Data Masking

Mascheramento
- Real-time
- Diversi tipi di maschere
- Mascheratura parziale

Basato su regole/permessi
- A livello di colonna
- Permesso di «unmask»

Configurazione Azure nel portale

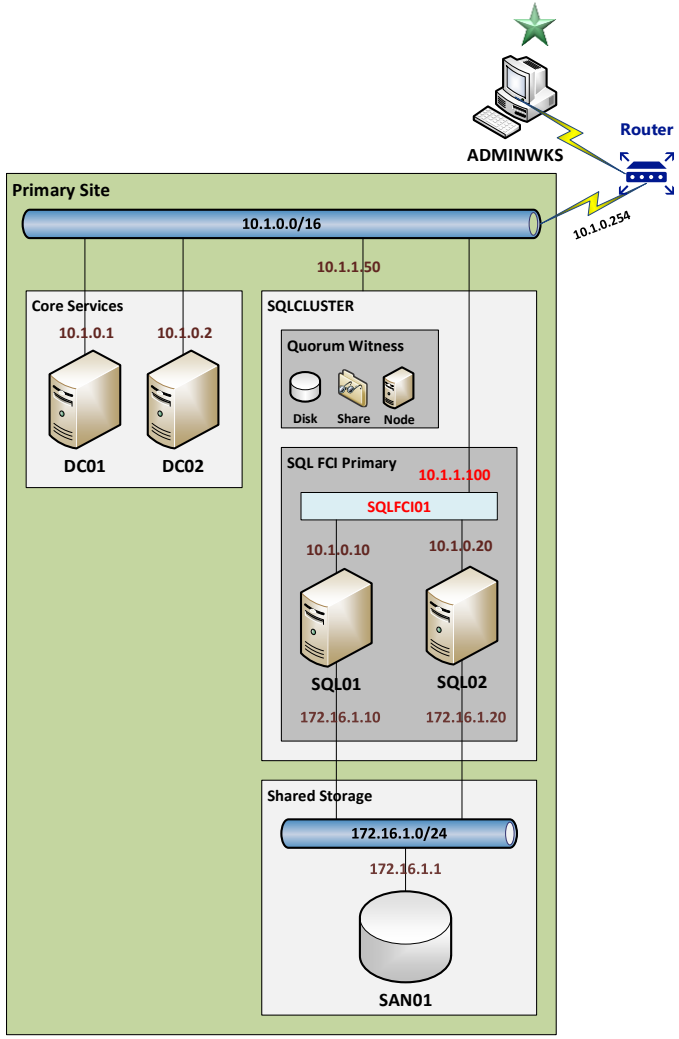


DEMO

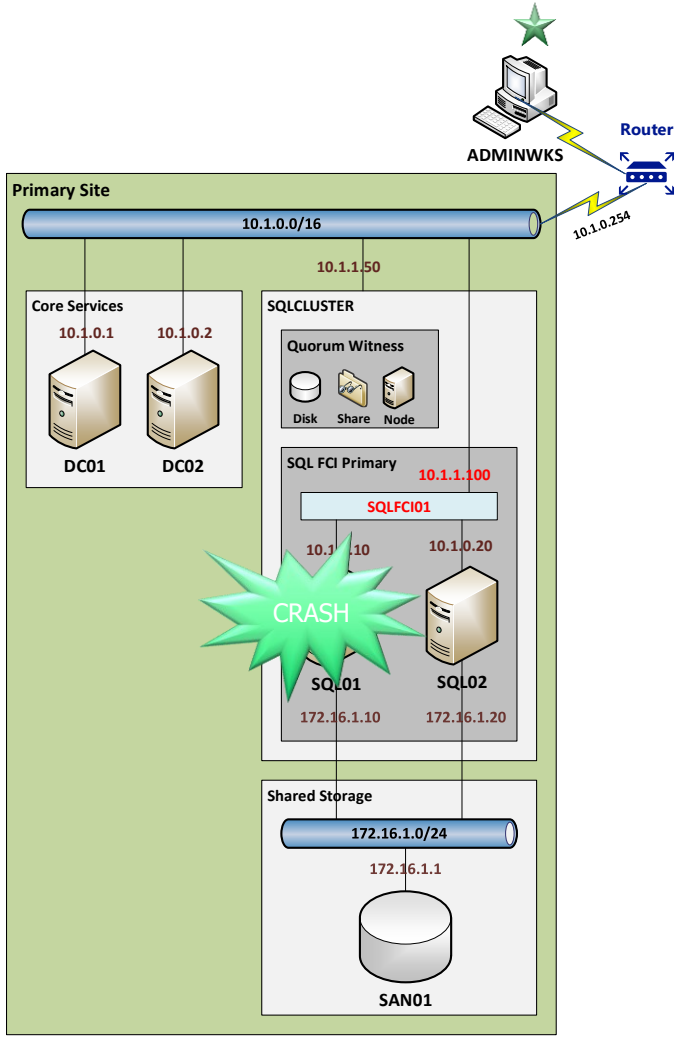
Protezione

Continuità del servizio

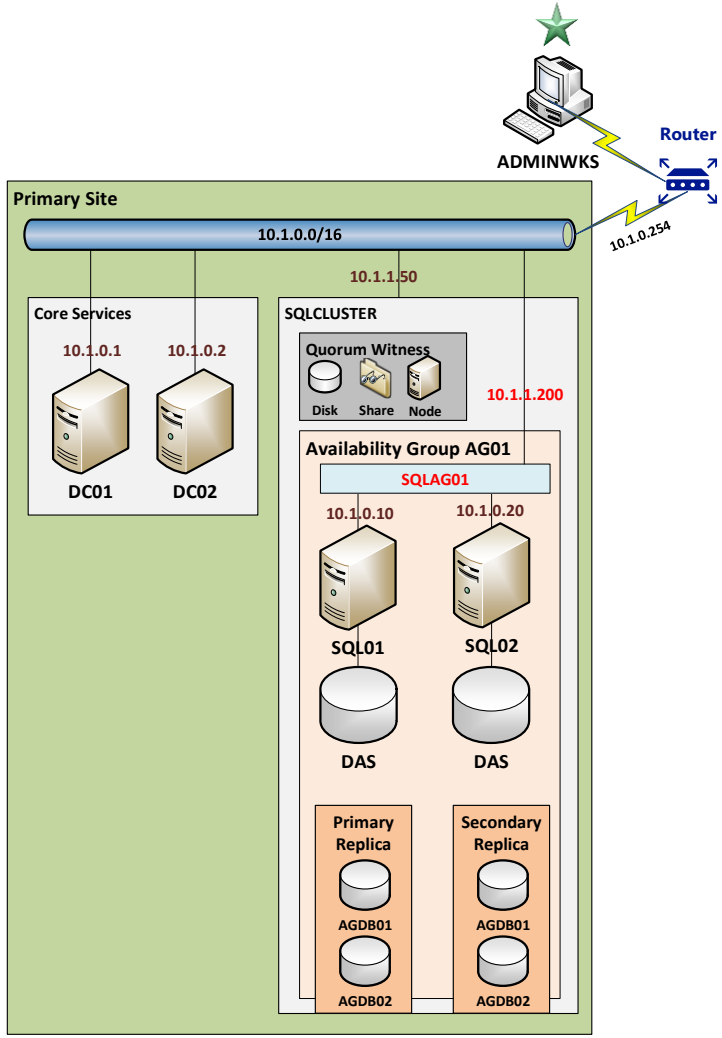
AlwaysOn Failover Cluster Instance



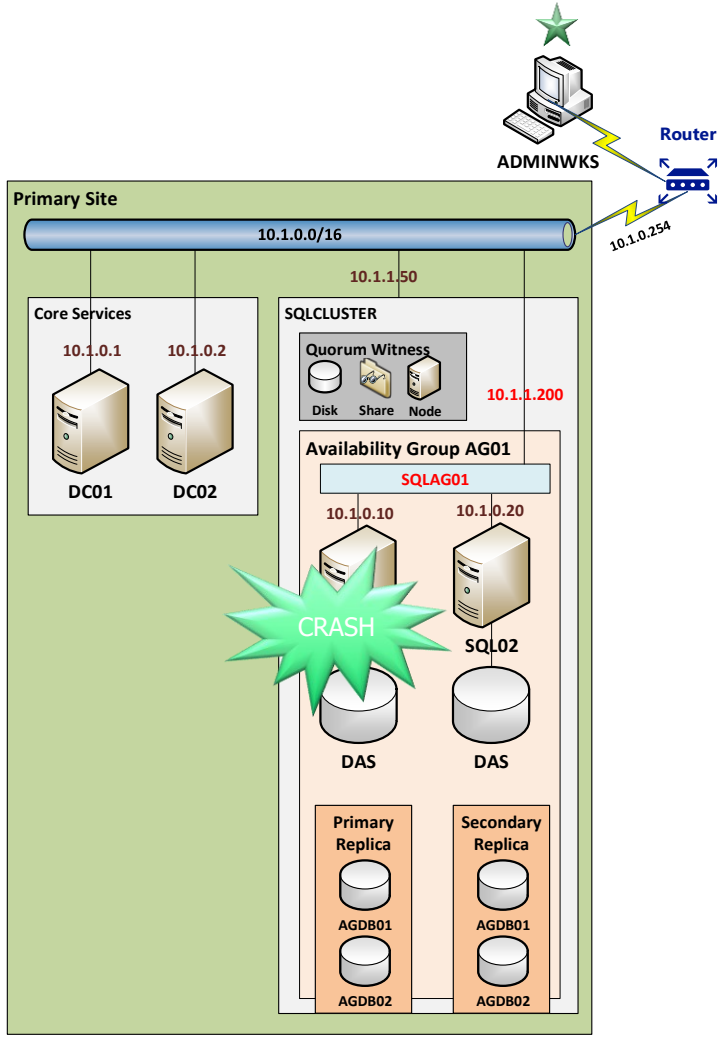
Indisponibilità nodo con AlwaysOn FCI



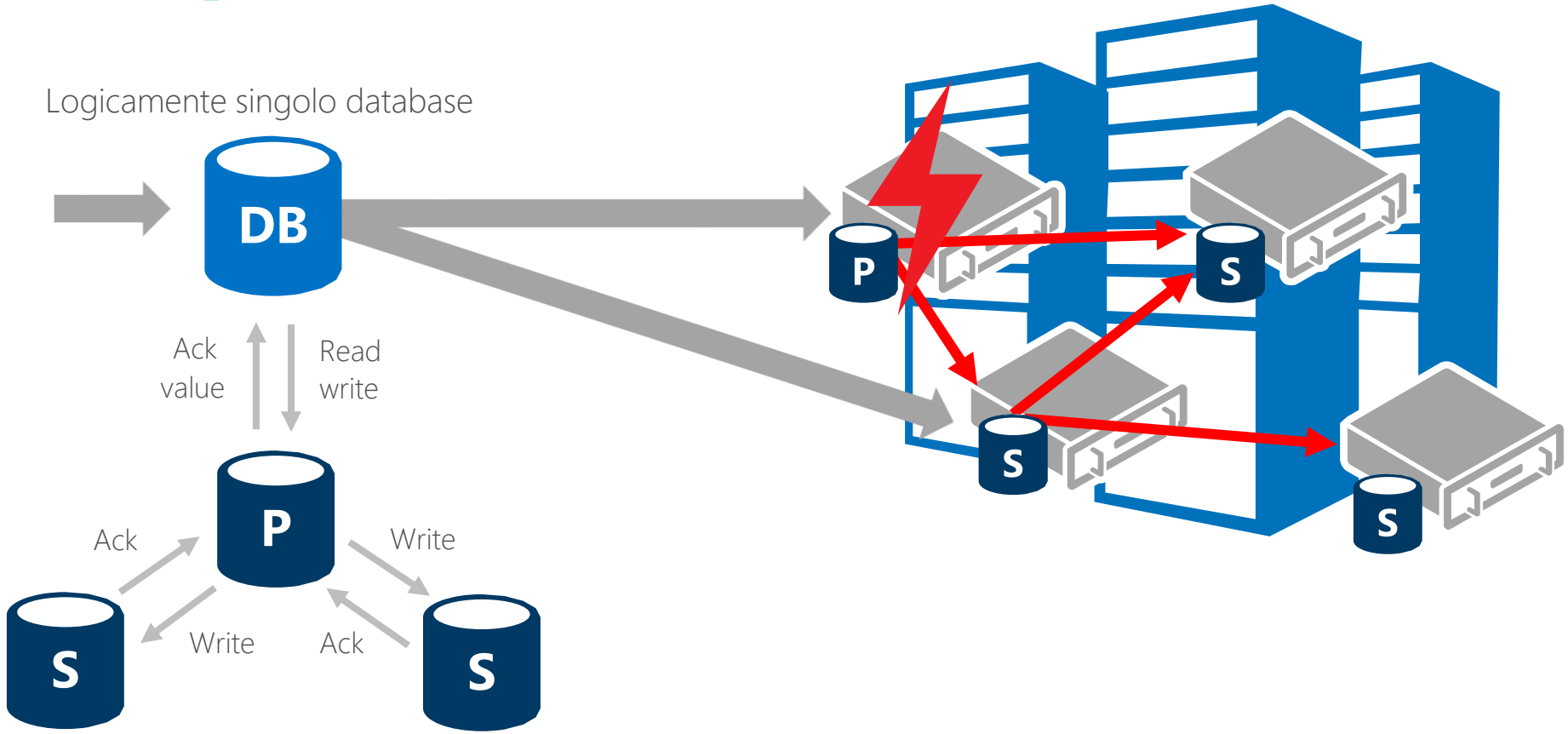
AlwaysOn Availability Groups



Indisponibilità nodo con AlwaysOn AG



Azure SQL Database



Possibilità di avere repliche geografiche

Standard 1 copia non accessibile, Active fino a 4 copie in sola lettura

Backup e restore

Diversi modelli componibili

- Completo (FULL), differenziale (DIFF), incrementale (LOG)

«Point-in-time»

- granularità fino a un punto in base a «retention»
- Richiede modello di recovery FULL e backup log

Possono essere crittografati

- Attenzione a non perdere le chiavi crittografiche!
- Automaticamente con TDE (default usa Database Key)

Backup & Restore in Azure SQL Database

Automatici

- «Full» settimanale
- «Differenziale» qualche ora
- «Log» ogni 5-10 minuti

«Backup set»

- Ridondati localmente
- Ridondati geograficamente (regione geo-politica affine)
- Long Term Backup Retention (in anteprima)
  - Settimanali mantenuti per 10 anni

Report e Revisione

Cosa tracciare

Accessi

- SQL Server Trace (Profiler, deprecato)
- SQL Server Audit

Dati modificati (versioni precedenti)

- Change Data Capture
- Temporal Databases

SQL Server Audit

Definizione gruppi di azioni da tracciare

- Server
- Database

Target

- File
- Windows Log

Disponibile con tutte le edizioni

- a partire da SQL Server 2016 Service Pack 1
- Implementazione diversa per Azure SQL Database

Azure SQL Database Threat Detection

Semplice opzione da attivare per database

- Richiede attivazione «SQL Database Auditing»

Rileva potenziali minacce/vulnerabilità

- Attacchi di tipo «SQL Injection»
- Accessi anomali (es. da luoghi anomali)

Allarmi

- In tempo reale
- Raccomandazioni cosa investigare/come mitigare/rimediare

Policy Based Management

Infrastruttura per

- Definizione «policy»
- Controllo conformità installazione con «policy»

Serie di «policy» conformi a Best Practice

- Categoria di policy per sicurezza!

Enterprise Policy Management Framework

- http://aka.ms/epmframework

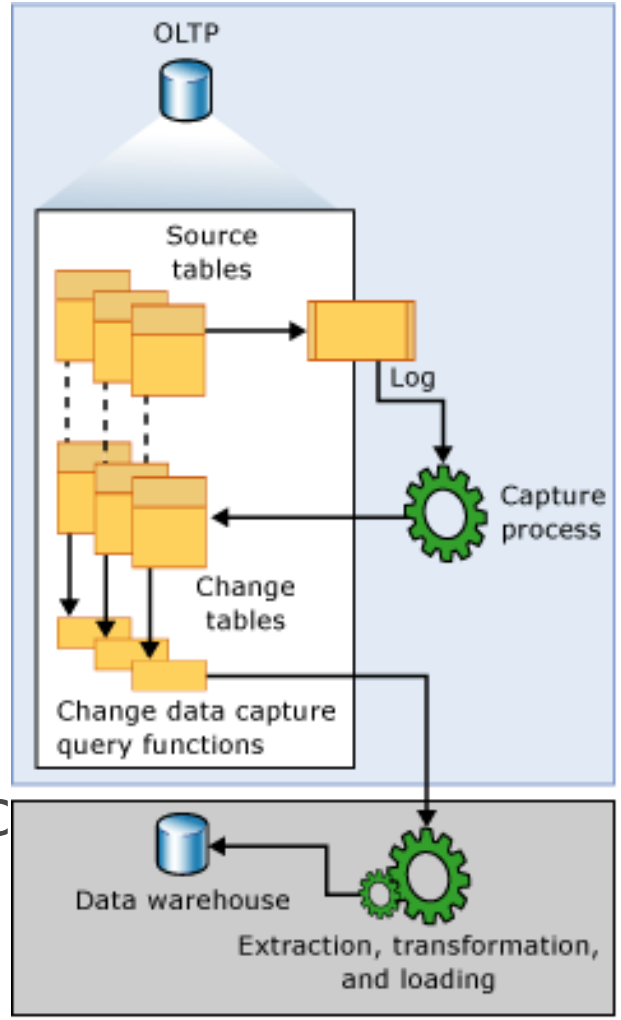
Change Data Capture

Soluzione tradizionale Audit modifiche dati?

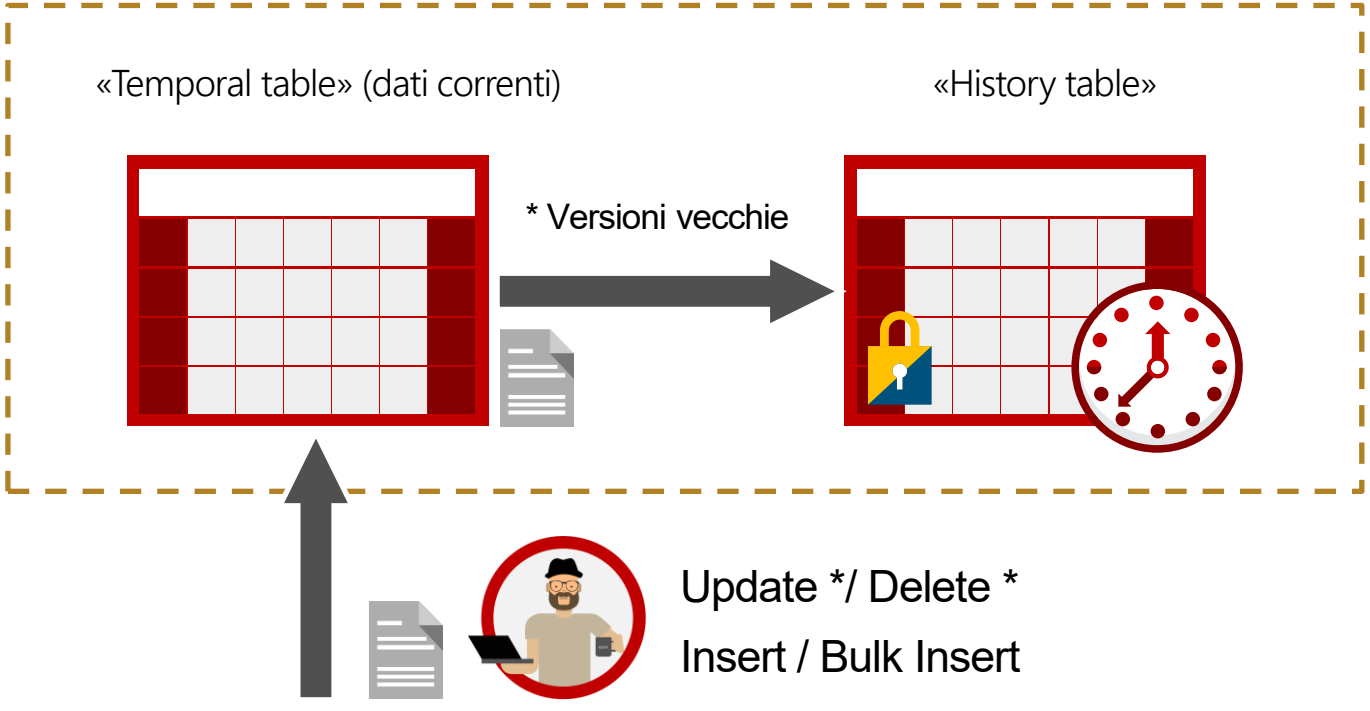
- Trigger! Ma…
- …complessità, prestazioni… ☹

CDC cattura automaticamente modifiche

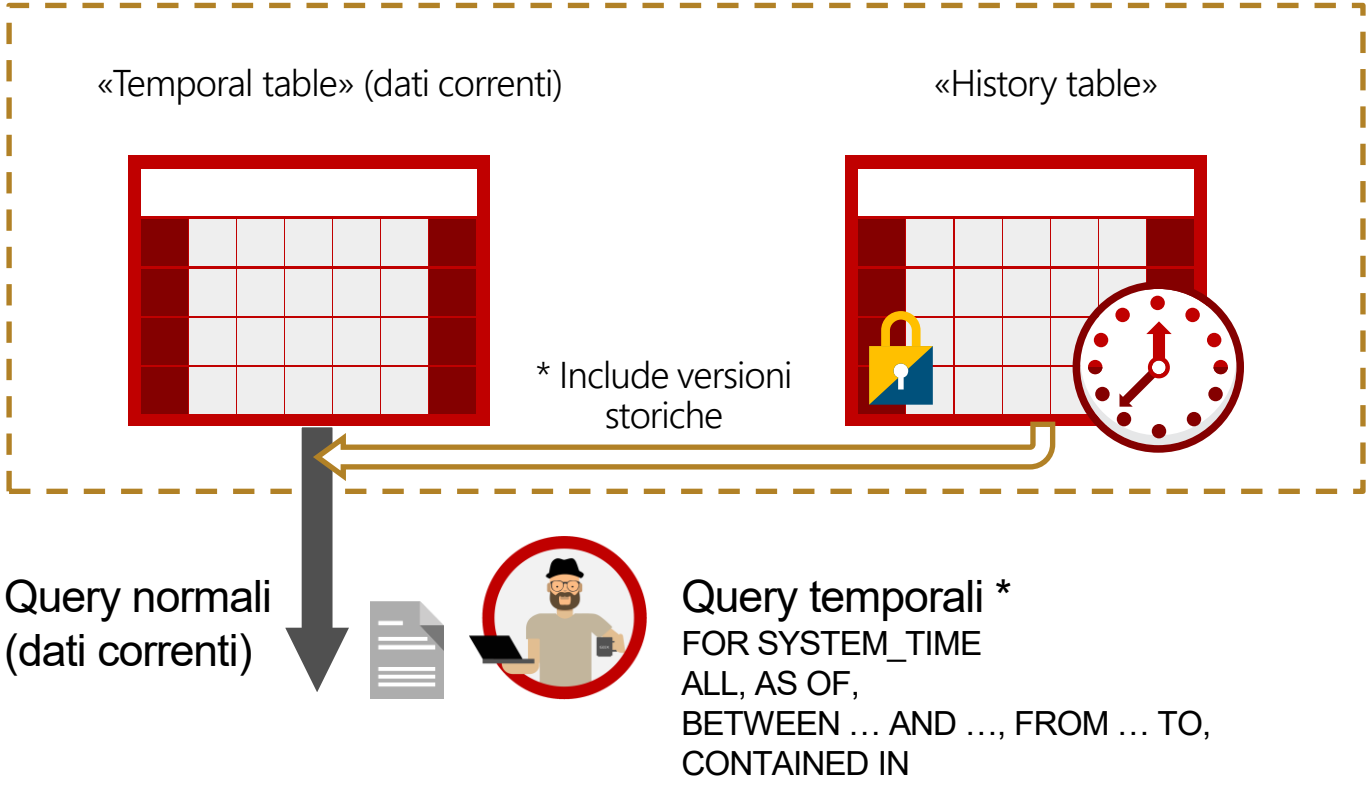
- Pensato principalmente per caricare DWH
- Genericamente va bene per tenere storico modific



Modifiche Database Temporali



Interrogazioni Database Temporali



Risorse GDPR

Regolamento ufficiale

http://data.consilium.europa.eu/doc/document/ST-9565-2015-INIT/en/pdf

Guide to enhancing privacy and addressing GDPR requirements with the Microsoft SQL platform

https://aka.ms/gdprsqlwhitepaper

Microsoft Trust Center

https://www.microsoft.com/GDPR

https://www.microsoft.com/it-it/trustcenter/privacy/GDPR

GRPR Detailed Assessment Toolkit

http://aka.ms/gdprdetailedassessment

Risorse Security generiche

White Papers

SQL Server 2012 Security Best Practices

http://bit.ly/2rLSJrg

SQL Server Security Blog

https://blogs.msdn.microsoft.com/sqlsecurity

Corso MVA

https://mva.microsoft.com/en-US/training-courses/16076

GitHub Samples

https://github.com/Microsoft/azure-sql-security-sample

https://github.com/Microsoft/sql-server-samples

Risorse Security specifiche

Transparent Data Encryption

https://blogs.msdn.microsoft.com/sqlsecurity/2016/10/05/feature-spotlight-transparent-data-encryption-tde

Always Encrypted

https://msdn.microsoft.com/en-us/library/mt163865.aspx

https://channel9.msdn.com/events/DataDriven/SQLServer2016/AlwaysEncrypted

https://channel9.msdn.com/events/Ignite/2016/BRK3151

Risorse Business Continuity

SQL Server 2014 From 0 to HA with Cluster & AlwaysOn

https://www.youtube.com/watch?v=YbF17toCd5Y

Azure & SQL Server: what's new

https://www.youtube.com/watch?v=MfADRPjvrzo

#SqlSat675